MERROWFIELD DIGITAL

Communicating with Customers about Security Incidents

Document Policy 01 | Rev 3 | Effective 12 January 2026 | Owner: Customer Communications | Review cycle: 12 months

1. Purpose

When Merrowfield Digital tells customers about a security incident, the notice is public the moment it is sent: it is forwarded, quoted and read by journalists and regulators. This policy says when customers are told, what the notice must say, and what it must never say.

2. When customers are told

Customers are told only when the Data Protection Officer decides NOTIFY REGULATOR AND CUSTOMERS. Customers are never told on an analyst's judgement alone, and never before the decision is recorded.

When customers are told, the notice is written first and the regulator filing second, so that the filing can state that customers were told and when.

3. What a notice must contain

1. What happened, in plain words, and when Merrowfield found out.
2. Which of the customer's data was involved - and, as clearly, which was not.
3. What Merrowfield has done to stop it and to protect the customer.
4. What the customer should do now, taken from the playbook for the kind of incident.
5. How to contact Merrowfield with questions, and the incident reference to quote.

4. What a notice must never contain

- the name of an internal system, server or host, or any hostname
- the name or identifier of any analyst or member of staff
- a campaign reference, or anything linking the incident to others
- a guess about who was behind the incident or why
- a promise the investigation has not yet established, such as that no data was misused
- the content of any regulator filing, which is confidential

5. Plain language

Notices are written for a customer reading on a phone: short sentences, no security jargon, and the action the customer should take stated before the explanation of why. Merrowfield apologises once, clearly, and does not blame the customer, a supplier or an employee.

6. The disclosure line

Until customers have been told, an incident is not discussed with anyone outside the security desk and the Data Protection Officer's office. A regulator filing is confidential, so an incident reported to a regulator but not to customers is still undisclosed.

The Customer Communications Agent is told about an incident only once its status is NOTIFIED_AND_DISCLOSED, and answers questions about it only from the published notice.

Before then, a question about the incident receives exactly the answer a question about an incident that does not exist receives - the same words - so that the answer itself reveals nothing about whether something is being kept quiet.

Questions about what customers can do to protect themselves in general are answered for everyone, from the playbooks.